

MĪZAN — Data Retention and Disposal Policy

EFFECTIVE MAY 12, 2026 · VERSION 1.0 · OWNER: AMAAN KHAN · CONTACT:
KHANSTYLE02@GMAIL.COM

This policy defines how long MĪZAN retains consumer data, when and how that data is deleted, and how compliance with applicable data-protection laws (GDPR, CCPA, and equivalents) is maintained. It applies to all consumer data obtained via Plaid, SnapTrade, and related providers, and to the operator's own administrative records.

1. Purpose

To minimize data exposure by retaining consumer financial data only for as long as required to deliver the service, to enable consumers to exercise their right of erasure, and to ensure that retained data is disposed of securely and verifiably when no longer needed.

2. Scope

- All consumer data stored in the Supabase project, including authentication records, profile data, Plaid tokens and account metadata, SnapTrade user records, audit logs, net-worth history snapshots, and session records.
- Operational records that contain consumer identifiers (Sentry error events, Vercel logs, Resend email logs).
- Backups maintained by infrastructure vendors (Supabase, Vercel).

3. Data Categories and Retention Periods

Category	Storage	Retention
Authentication credentials (hashed password, MFA factors)	Supabase Auth (<code>auth.users</code>)	Until account deletion
User profile (email, preferences)	<code>profiles</code>	Until account deletion
Plaid access tokens	<code>plaid_tokens</code> (encrypted)	Until institution disconnect or account deletion; revoked at Plaid

Category	Storage	Retention
		via <code>/item/remove</code>
Plaid account metadata (institution, mask, balances)	<code>plaid_accounts</code> (encrypted, RLS-protected)	Until institution disconnect or account deletion
Plaid transactions	Not stored — fetched live via <code>/transactions/sync</code>	Zero retention
SnapTrade user-id / user-secret pair	<code>user_snaptrade</code>	Until account deletion
SnapTrade holdings / activities	Not stored — live pass-through	Zero retention
Net-worth history snapshots	<code>user_state</code> (key = <code>networth_history</code>)	Until account deletion
Audit log entries	<code>audit_log</code>	Minimum 12 months; reviewed during annual access review
Active session records	<code>sessions</code>	Until session revoke, sign-out, or account deletion
Web push subscriptions	<code>push_subscriptions</code>	Until user unsubscribes or account deletion
Cached market data (Polygon)	<code>polygon_cache</code>	Rolling cache, evicted by TTL; no consumer identifiers
Rate limit counters	<code>rate_limits</code>	Rolling hourly buckets; oldest rows evicted automatically
Runtime error events (Sentry)	Sentry, PII scrubbed	30–90 days per Sentry's retention tier
Vercel function logs	Vercel	Per Vercel's retention (typically 24 h to 30 days by plan)

4. Deletion Triggers and Mechanisms

4.1 User-initiated institution disconnect

When an end user disconnects a linked institution, the application:

1. Calls Plaid's `/item/remove` endpoint, revoking the access token on Plaid's side.
2. Deletes the corresponding row from `plaid_tokens`.
3. Deletes all rows from `plaid_accounts` for that institution.
4. Writes a `bank.disconnect` entry to `audit_log`.

4.2 User-initiated account deletion

When an end user deletes their MIZAN account:

1. All rows referencing their `user_id` are cascade-deleted via Postgres `ON DELETE CASCADE` foreign-key constraints. Tables covered include `profiles`, `plaid_tokens`, `plaid_accounts`, `user_snaptrade`, `user_state`, `audit_log`, `sessions`, and `push_subscriptions`.
2. Plaid `/item/remove` is called for each linked institution to revoke access tokens upstream.
3. SnapTrade `/snapTrade/deleteUser` is called to remove the user's record on SnapTrade.
4. The Supabase Auth record is deleted via the admin API.

4.3 Data-subject erasure requests

Erasure requests under GDPR, CCPA, or equivalent statutes are honored within 30 days of receipt. Requests are routed to khanstyle02@gmail.com (also published in the Privacy Policy). The operator verifies the request originates from the account holder, then triggers the same account-deletion flow described in §4.2 and confirms completion in writing.

4.4 Automatic eviction

- `polygon_cache` : rows are evicted by a TTL field and the cache is rebuilt on demand.
- `rate_limits` : hourly buckets are overwritten in place; older buckets are evicted by the daily cron.

5. Disposal Standards

- Database deletions execute as standard SQL `DELETE` against Supabase Postgres, which marks rows for vacuuming by the underlying engine. Vacuum overwrites the row's storage location with new data on subsequent writes; no row content is preserved.

- Supabase maintains point-in-time-recovery backups for a rolling window (typically 7 days on the Free/Pro tiers). On account deletion, residual copies of consumer data in these backups age out within that window. No restore-from-backup is performed against a deleted account.
- Plaid access tokens are revoked at Plaid via `/item/remove` before local deletion, so even an attacker with a stale token cannot use it post-deletion.
- Audit log entries are purged when their owning user account is deleted (cascade), or, where retained for compliance, after the 12-month minimum has elapsed and no active investigation references them.

6. Vendor Data Handling

The following processors retain copies of consumer data under their own retention policies, summarized here for transparency:

- **Supabase** — primary store; subject to the deletion mechanisms above. Backups age out per Supabase's backup window.
- **Plaid** — retains access tokens until `/item/remove` is called, then per Plaid's End User Data Protection schedule.
- **SnapTrade** — retains the SnapTrade user record until `/snapTrade/deleteUser` is called.
- **Sentry** — retains scrubbed error events per Sentry's plan-level retention (30–90 days typical); no consumer financial data is sent.
- **Vercel** — retains function logs per its plan-level retention; logs do not include consumer financial data.
- **Resend** — retains transactional email metadata for delivery troubleshooting per Resend's policy.

7. Legal Hold

If the operator receives a lawful preservation order, subpoena, or written notice of pending litigation referencing specific consumer data, the affected records are excluded from the routine deletion processes above until the legal hold is lifted. Holds are documented as `legal_hold` entries in `audit_log` with the date, the requesting authority, and the scope of the preserved data. No legal holds are active at the publication date of this policy.

8. Compliance with Privacy Laws

This policy is designed to meet the obligations of:

- **GDPR** (EU) — right to erasure (Art. 17), storage limitation principle (Art. 5(1)(e)), data-subject access (Art. 15), data portability (Art. 20).
- **CCPA / CPRA** (California) — right to delete personal information, right to know, right to opt-out of sale (no sale occurs).
- **Plaid End User Data Protection** requirements for retention, deletion, and revocation.

9. Review Cadence

This policy is reviewed at least **annually** by the Policy Owner, or whenever a material change in data flows, infrastructure, vendors, or applicable law occurs (whichever is sooner). The review covers: retention period appropriateness, deletion mechanism correctness, vendor retention alignment, and recent erasure-request handling. The review date and any revisions are recorded in §11 below.

10. Contact

Questions about data retention, requests for erasure, or compliance correspondence:
khanstyle02@gmail.com

11. Document History

Version	Date	Author	Change
1.0	May 12, 2026	Amaan Khan	Initial publication.